

공장에너지관리시스템(FEMS)

보안

가이드라인

공장에너지관리 시스템 보안 가이드라인

FACTORY ENERGY MANAGEMENT SYSTEM
SECURITY GUIDELINE



목 차

1. 목적	1
2. FEMS 표준 플랫폼 개요	1
3. FEMS 표준 플랫폼 개념도	3
4. 적용대상 및 범위	3
5. FEMS 보안 위협 (KISA, 스마트에너지 사이버보안 가이드 참조)	4
5.1 CLOUD FEMS 운영센터 보안 위협	4
5.2 ON-PREMISE FEMS 보안 위협	6
5.3 FEMS 네트워크 보안 위협	7
5.4 FEMS 기기 보안 위협	8
6. FEMS 보안 요구사항 (KISA, 스마트에너지 사이버보안 가이드 참조)	9
7. FEMS 네트워크 및 시스템 보안 대책	11
7.1 FEMS 관련 산업제어시스템(ICS) 보안 표준(NIST 800-82 ICS 보안 가이드)	11
7.2 FEMS 네트워크 및 시스템 보안 대책	16
7.2.1 FEMS 운영센터 내부 네트워크 구성	16
7.2.2 FEMS 운영센터 연계구간 네트워크 구성	17
7.2.3 FEMS 실증사이트 내부 네트워크 구성	18
7.2.4 클라우드 플랫폼(Docker, Kubernetes)기반 FEMS 시스템 보안 대책	19
7.2.5 글로벌 클라우드 서비스 플랫폼 적용시 보안 대책	21
8. FEMS 데이터 및 통신 보안 대책	22
8.1 CLOUD FEMS의 데이터 및 통신 보안 대책	22
8.2 ON-PREMISE FEMS의 데이터 및 통신 보안 구조	22
8.3 CLOUD FEMS 운영센터 내부 데이터 및 서비스 통신 보안 대책	23
9. 참고문헌	27

1. 목적

본 보안 가이드는 표준 FEMS 플랫폼 구축 및 운영에 있어서 사이버 보안을 확보하기 위하여 FEMS 플랫폼 보안 적용 대상 및 보안 위협을 정의하고, 관련 보안 대책을 제시함으로써 사이버 공격으로부터 FEMS(Factory Energy Management System) 플랫폼을 안전하게 보호하는 것을 목적으로 한다.

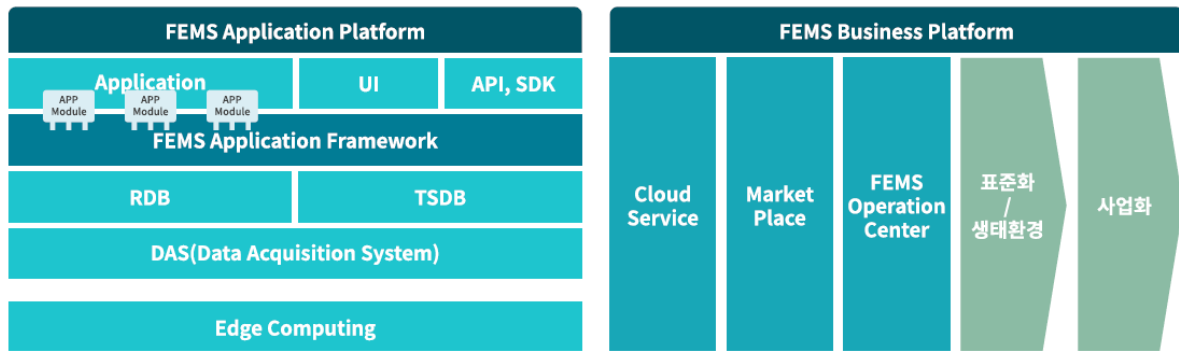
2. FEMS 표준 플랫폼 개요

본 과제를 통해서 개발하고자하는 기술은 표준 체계에 따르는 FEMS 어플리케이션 플랫폼과 FEMS 보급확산을 돕는 비즈니스 플랫폼으로 크게 나눌 수 있다. FEMS 어플리케이션 플랫폼은 에너지 운영 현황과 운영 실적을 관리하는 EIS(Energy Information System) 서비스와 에너지 최적화를 제공하는 EOS(Energy Optimization System) 서비스를 제공한다. EIS 서비스를 제공하기 위한 FEMS 시스템은 제공 기능 범위에 따라 **배포형**(Entry), **기본형**(Essence), **고급형**(Premium), **전문형**(Professional), **연계형**, **서비스형** 모델로 구분할 수 있으며, 각 모델은 표준 체계에 따라 개발되어야 한다.

- 배포형, 기본형: ISO50001 체계에 따른 PDCA(Plan-Do-Check-Act)를 지원하고, **가시화(모니터링-에너지 사용량/비용관리, 에너지 품질관리, 에너지 성능 관리, 트래킹-에너지 실적관리, 에너지 추세관리, 에너지 변경점 관리 등)** 위주 기능 제공, 특히 취급 관제점과 에너지종이 적은 경우(예: 관제점 20 개, 에너지 2 종) 배포형으로 정의
- 고급형: 전사 관점의 에너지 관리(에너지밸런스, 수급관리)를 제공하며, 베이스라인과 현재를 비교분석하여 현재 에너지의 적정성 평가 기능 제공
- 전문형: 스마트 팩토리 관점의 공정진단 및 설비진단 기능 제공
- 연계형: 에너지 신산업과 같은 타 시스템 연계(예: RE100(100%Renewable Energy), 신재생에너지, DR(Demand Response), ESS(Energy Storage System)) 기능 제공
- 서비스형: 클라우드 서비스 형태로 FEMS 서비스 제공

FEMS 어플리케이션 플랫폼의 EOS 서비스는 유틸리티 에너지(압축공기, 냉수, 스팀 등) 최적화와 공정 설비 운전 최적화 기능을 제공하며, 스마트 유틸리티와 스마트 공정 표준 체계에 따라 개발되어야 한다.

비즈니스 플랫폼은 FEMS 시스템의 보급 확산을 돕기 위하여, 공장에너지관리용 PaaS(Platform as a service) 플랫폼을 지원하는 클라우드 서비스, FEMS 서비스 및 설비(장치) 구매를 지원하는 마켓플레이스, 개별사업장 또는 그룹사업장의 FEMS 운영상태를 관리하는 FEMS 운영 센터로 구성된다.



<FEMS 표준 플랫폼 개념도>

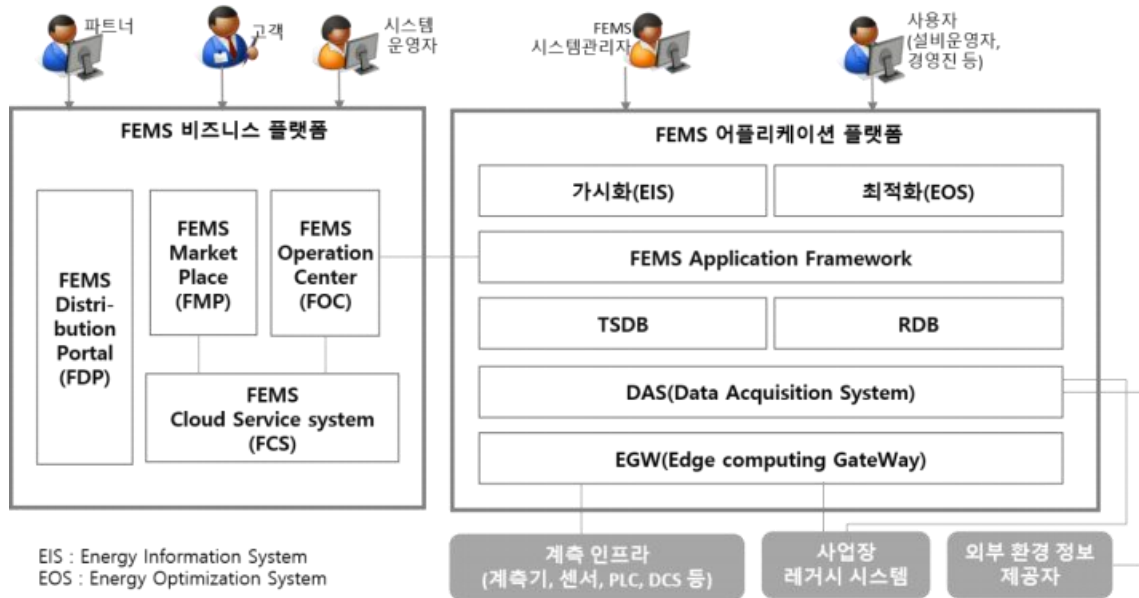
본 사업의 목표 달성을 위한 주요 연구개발 대상 기술은 다음과 같다.

범주	주요 기술	기술 세부 분류
FEMS 어플리케이션 플랫폼	엣지컴퓨팅게이트웨이	FEMS 현장데이터 수집 기술
		FEMS 현장데이터 처리 기술
	데이터 수집처리	FEMS 수집데이터 처리 기술
		FEMS 수집데이터 저장 기술
	어플리케이션 프레임워크	UI 공통 프레임워크 구축
		UI Studio 기술
		어플리케이션 공통 프레임워크 구축 (예: Java framework, Python framework)
		기존정보체계 기술
		SDK 및 Open API 기술
	에너지 가시화(EIS)	에너지 모니터링 기술
		에너지 트래킹 기술
	에너지 최적화(EOS)	분석 및 예측 기술
		시뮬레이션 기술
		제어 - 스마트 유틸리티 기술
		제어 - 스마트 공정 기술
FEMS 비즈니스 플랫폼	FEMS 클라우드 서비스	클라우드 자원 및 FEMS 운영 상태 모니터링 기술
		클라우드 가상 자원 구성 및 FEMS 패키지 배포 기술
	FEMS 마켓플레이스	상품 구매를 지원하는 고객 서비스
		신규 서비스 및 장치 상품 런칭을 지원하는 파트너 서비스
	FEMS 운영 센터	FEMS 사업장 유지관리
		FEMS 사업장 통합 모니터링

- UI: user interface

- SDK: Software Development Kit
- FOC: FEMS Operation Center

3. FEMS 표준 플랫폼 개념도



<시스템 개념도>

TSDB: Time series Database

RDB: Realtional Database

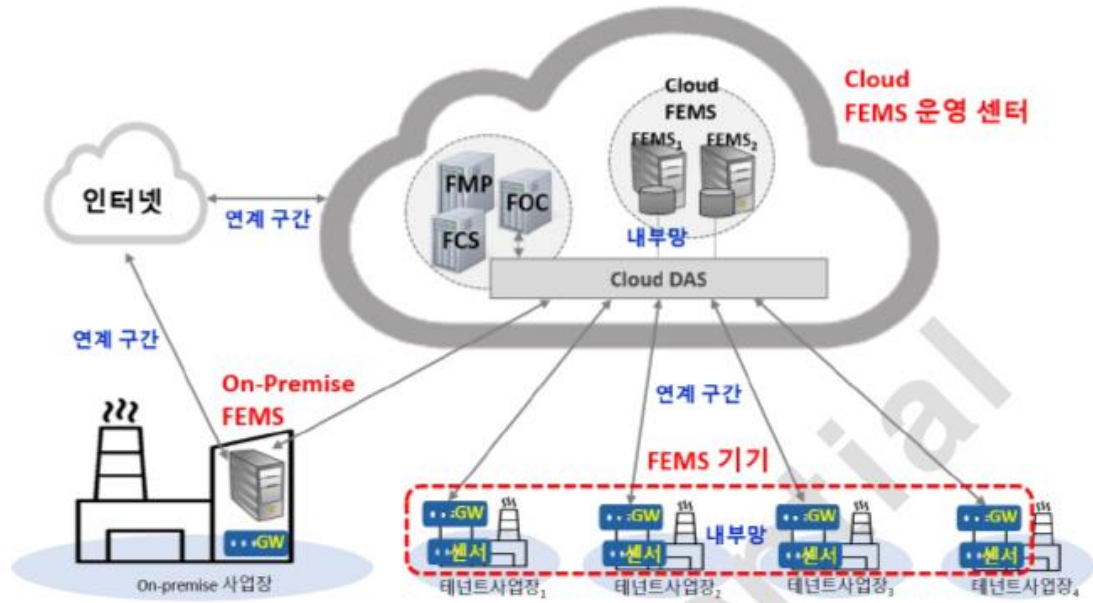
4. 적용대상 및 범위

본 보안 가이드의 적용대상은 Cloud FEMS 운영센터, On-Premise FEMS, FEMS 네트워크, FEMS 기기를 포함한다.

- **Cloud FEMS 운영 센터**는 Cloud 상에 FEMS Pod, Container 실행 환경을 제공하고 FEMS를 통합 운영 및 관리하기 위하여 FOC, FMP(FEMS Market Place), FCS(FEMS Cloud service System), Cloud DAS(Data Acquisition System), FEMS 컨테이너를 포함한다.
- **On-Premise FEMS**는 공장 사이트 내에 구축되며 공장 내부 네트워크를 통해 FEMS 기기들과 연결된다.
- **FEMS 네트워크**는 Cloud 및 공장 내부 네트워크와 연계 구간으로 구분하며, 연계 구

간은 Cloud FEMS 운영 센터와 FEMS 기기(또는 On-premise FEMS), Cloud FEMS (또는 On-premise FEMS)와 인터넷 간 연계 구간을 의미한다.

- FEMS 기기는 EdgeGW와 각종 계측기기 및 공장 설비들을 포함한다.



<적용 대상 및 범위>

5. FEMS 보안 위협 (KISA, 스마트에너지 사이버보안 가이드 참조)

5.1 Cloud FEMS 운영센터 보안 위협

- 서비스 위장
 - FEMS 서비스 요청 시 위조된 IP(Internet Protocol) 패킷 및 DNS(Domain Name System) 패킷을 삽입하여 악의적인 사이트로 연결 유도
 - 공격자는 FEMS 시스템으로 위장하여 FEMS 실증 사이트 또는 기기에 불법 제어명령을 전송할 수 있음
- FEMS 앱(Pod, Docker container, FEMS SDK 등) 및 데이터 위/변조
 - FEMS 앱/설정 정보 위/변조를 통해 악의적인 서비스를 설치하여 제어권 획득
 - 에너지 수집/분석 데이터 및 이벤트 메시지 등을 위/변조
 - 공격자는 정보시스템에 저장되어 있는 FEMS 운영정보 및 개인정보를 위조 및 파괴

할 수 있음

- 공격자는 네트워크에 송수신되는 패킷을 가로채고 위조된 패킷을 전송하거나 파괴할 수 있음
- 공격자는 시스템 불법 접근 기록, 시스템 설정 변경 기록과 같은 시스템 이벤트 및 로그 기록을 위조 또는 삭제할 수 있음
- 공격자는 취약한 암호 알고리즘으로 생성된 MAC(Message Authentication Code) 값을 위조할 수 있음

● 메시지 부인

- EdgeGW로부터의 이벤트 및 제어 결과 등에 대한 메시지 전송 사실 부인
- 고객/파트너사와의 FEMS 클라우드 서비스 계약 내용 부인

● 정보 유출

- FEMS 관리 기준 정보, 태그 정보, 관리 대상 EdgeGW 정보, FEMS 앱 등 중요 정보의 유출 시도
- 공격자는 정보시스템에 저장되어 있는 FEMS 운영정보 및 개인정보를 획득 및 유출할 수 있음
- 공격자는 위장한 FEMS 시스템으로 실증사이트 시스템 및 기기에 정보 요청 메시지를 전송하여 중요정보를 획득 및 유출할 수 있음
- 공격자는 네트워크에 송수신되는 패킷 수집을 통해 중요정보를 획득 및 유출할 수 있음
- 공격자는 네트워크 라우팅 정보 위조를 통한 패킷 수집을 통해 중요정보를 획득 및 유출할 수 있음
- 공격자는 취약한 암호 알고리즘으로 암호화된 데이터를 복호화하여 중요 정보를 획득 및 유출할 수 있음

● 서비스 거부

- DDoS 공격을 통해 Cloud FEMS로 접근하지 못하도록 하거나 서비스 정지 및 오버헤드를 유발
- 관리 대상 사업장의 에너지 정보 수집 및 제어 등을 수행하지 못하도록 모든 통신을 차단 시도
- 공격자는 다량의 트래픽 발생, 다수의 접속 시도, 취약점을 악용해 FEMS 시스템 및

네트워크에 서비스 거부 공격을 할 수 있음

- 공격자는 네트워크 라우팅 정보를 위조하여 특정 시스템으로 향하는 통신경로를 단절시키는 방법을 통해 해당 시스템에 서비스 거부 공격을 할 수 있음
- 공격자는 스위치 및 라우터 해킹을 통해 네트워크 서비스 거부 공격을 할 수 있음

● 권한 상승

- 서비스 가입자, 운영자의 취약한 로그인 계정, 부적절한 접근권한 취약점을 통해 서비스 가입자 과금 정보, 고객 프로파일, 암호키 등 권한 범위 이외의 민감 정보에 접근 시도
- 공격자는 취약한 로그인 계정을 추측하여 시스템 접근권한을 획득할 수 있음
- 공격자는 취약한 원격접속서비스 (Telnet, FTP, Web 등) 계정을 추측하여 시스템 접근권한을 획득할 수 있음
- 공격자는 시스템 운영체제 취약점을 통해 시스템 접근권한을 획득할 수 있음
- 공격자는 웹, 응용프로그램 취약점을 통해 시스템 접근권한을 획득할 수 있음
- 공격자는 시스템 원격접속서비스 취약점을 통해 시스템 접근권한을 획득할 수 있음
- 공격자는 시스템에서 불필요하게 운영되는 서비스들의 취약점을 통해 시스템 접근권한을 획득할 수 있음

● 운영 센터 침해 공격

- 웹서비스 또는 Cloud 서비스 환경(Docker, Kubernetes 등)의 보안 취약점을 이용하여 시스템을 공격

5.2 On-Premise FEMS 보안 위협

● 서비스 위장

- 서비스 요청 시 위조된 IP 패킷 및 DNS 패킷을 삽입하여 악의적인 사이트로 연결 유도

● FEMS 앱(Pod, Docker container, FEMS SDK 등) 및 데이터 위/변조

- FEMS 앱/설정 정보 위/변조를 통해 악의적인 서비스를 설치하여 제어권 획득
- 에너지 수집/분석 데이터 및 이벤트 메시지 등을 위/변조

- 메시지 부인
 - EdgeGW로부터의 이벤트 및 제어 결과 등에 대한 메시지 전송 사실 부인
 - FOC로부터의 제어 요청 메시지 전송 사실 부인
- 정보 유출
 - FEMS 관리 기준 정보, 태그 정보, 관리 대상 Edge 게이트웨이 정보 등 중요 정보의 유출 시도
- 서비스 거부
 - DDoS 공격을 통해 FEMS로 접근하지 못하도록 하거나 서비스 정지 및 오버헤드를 유발
 - 관리 대상 사업장의 에너지 효율 제어 등을 수행하지 못하도록 모든 통신을 차단 시도
- 권한 상승
 - FEMS 운영자의 취약한 로그인 계정, 부적절한 접근권한 취약점을 통해 에지 게이트웨이에 접근 시도
- FEMS 침해 공격
 - FEMS 내부 시스템 및 네트워크에 대한 보안 취약점을 이용하여 시스템을 공격

5.3 FEMS 네트워크 보안 위협

- 네트워크를 통해 전송되는 중요 정보 유출 및 위·변조
 - FEMS 주요 기능 모듈간 교환되는 메시지에 대해 유출 및 변조 시도
- 중요 정보에 대한 부인 공격 및 비인가 기기/사용자 접근
- DDoS(Distributed Denial of Service) 공격
 - 주요 구성요소에 대한 DDoS 공격을 시도하여 정상적인 통신을 방해
 - 네트워크 취약점을 악용하여 스마트미터 물리적 조작 또는 악성 소프트웨어 설치
- 무선통신 감청을 통해 재송신 공격
- 외부로부터 연결된 네트워크를 통해 인가되지 않은 통신 데이터 유입을 시도

5.4 FEMS 기기 보안 위협

- 기기/펌웨어/데이터 위/변조
 - 에너지 수집 및 분석 데이터 및 이벤트 메시지 등을 위/변조
 - 공격자는 원격으로 배포되는 펌웨어 및 응용프로그램 소프트웨어 위조를 통해 악성코드를 설치할 수 있음
 - 공격자는 관리용 통신포트를 통해 악성코드를 설치할 수 있음
 - 공격자는 악성코드에 감염된 기기를 통해 다른 기기에 악성코드를 감염시킬 수 있음
 - 공격자는 기기에 물리적으로 접근하여 기기 메모리에 저장되어 있는 중요정보를 위조 및 파괴할 수 있음
 - 공격자는 운영센터 및 다른 기기로 전송되는 패킷을 가로채고 위조된 패킷을 전송하거나 파괴할 수 있음
 - 공격자는 취약한 암호 알고리즘으로 생성된 MAC 값을 위조할 수 있음
 - 공격자는 정상 기기의 식별자, 암호키, 인증 데이터 정보 복제를 통해 기기를 복제할 수 있음
 - 공격자는 기기 저장 정보 변경을 통해 기기를 위조할 수 있음
- 정보 유출
 - 관제점 태그 정보, 관리 대상 EdgeGW 구성/설정 정보 등 중요 정보의 유출 시도
 - 공격자는 기기 메모리에 저장되어 있는 중요정보를 획득 및 유출할 수 있음
 - 공격자는 DCU(Data Concentrator Unit), EdgeGW 등을 해킹해 중요정보를 획득 및 유출할 수 있음
 - 공격자는 위장한 FEMS 시스템으로 실증 사이트 기기에 정보 요청 메시지를 전송하여 중요정보를 획득 및 유출할 수 있음
 - 공격자는 취약한 암호 알고리즘으로 암호화된 데이터를 복호화하여 중요정보를 획득 및 유출할 수 있음
- 메시지 부인
 - FOC 또는 On-Premise FEMS로부터의 제어 요청 메시지 전송 사실 부인 (EdgeGW)

- 에너지 효율 향상을 위한 공장 설비 제어 사실 부인 (EdgeGW)
- 권한 상승
 - Web HMI(Human machine interaction) 운영자의 취약한 로그인 계정, 부적절한 접근 권한 취약점을 통해 에지 게이트웨이에 접근 시도
 - 운영자 계정 획득을 통한 악의적인 EdgeGW 설정정보 변경 및 공장 설비 제어
 - 공격자는 기기 관리용 통신 포트의 관리자 계정을 추측하여 기기 접근권한을 획득할 수 있음
 - 공격자는 기기 원격접속서비스 (Telnet, FTP, Web 등) 계정을 추측하여 기기 접근권한을 획득할 수 있음
 - 공격자는 기기 응용프로그램 취약점을 통해 기기 접근권한을 획득할 수 있음
 - 공격자는 기기 원격접속서비스 취약점을 통해 기기 접근권한을 획득할 수 있음
 - 공격자는 기기에서 불필요하게 운영되는 서비스들의 취약점을 통해 기기 접근권한을 획득할 수 있음
- 서비스 거부
 - 네트워크에 유/무선 통신장비를 이용하여 대역폭 이상의 트래픽을 발생시키거나 기기의 취약점을 공격하여 서비스 정지 및 오버헤드를 유발하는 서비스 거부 공격
- 물리적 FEMS 기기 공격
 - 물리적으로 접근하여 기기를 불법적으로 개조/복제/위조하거나 제거

6. FEMS 보안 요구사항 (KISA, 스마트에너지 사이버보안 가이드 참조)

- FEMS 데이터 보호: FEMS에 저장된 정보(사용자 및 FEMS 기기 정보, 수집 및 분석 정보, 제어 정보, 실행코드/이미지/패키지 등) 보호를 통한 기밀성 및 무결성을 보장하고, 운영 도메인 접속에 필요한 가입자 정보(가입자 식별자, 기기 식별자, 가입자 지리 정보)에 대한 기밀성을 보장
 - FEMS 데이터 암호화: 암호 알고리즘 및 안전한 키관리 적용
 - FEMS 데이터 무결성 검증: 해시 함수, 메시지 인증코드, 전자서명 등의 암호 알고리즘을 사용하여 저장 정보 변조 확인

- FEMS 데이터 이중화: 천재지변과 같은 예기치 못한 상황으로 인한 서비스 장애 대비
- FEMS 데이터 백업: 데이터의 손실이 일어난 경우 데이터 복구, 백업시스템의 주기적인 점검을 통해 백업 데이터의 신뢰성과 무결성 보장
- FEMS 메모리 접근 보호: 악성코드를 통한 데이터 유출을 방지
- FEMS 물리적 접근 보호: 비인가 물리적 접근을 통한 기기 및 시스템의 조작을 방지
- 완전삭제: 삭제된 정보가 복구 불가능도록 '0'으로 덮어쓰기 수행
- FEMS 네트워크 보안: 네트워크를 통해 전송되는 중요 정보 유출 및 위·변조 방지, 중요 정보에 대한 부인 공격 및 비인가 기기/사용자 접근 방지 기능 구현
 - 통신보안 적용: 전송채널 보호(SSL/VPN 등)를 통해 메시지 스니핑 방어
 - 기기 인증 및 부인 방지: PKI(Public key Infrastructure), 전자서명 등 인증 방안 적용
 - 상호인증: 인증서 기반의 상호인증 기능을 제공하는 TLSv2 또는 DTLSv2 적용
 - 메시지 위·변조 검사: 위·변조된 메시지로 인한 피해를 막기 위해 해시함수 적용
 - 메시지 인증: EAP-TLS, EAP-IKEv2 등을 사용하여 메시지 인증 코드 검증을 통해 비인가 트래픽 차단
 - DDoS 공격 방어: 통신 프로토콜 자체에서 DDoS 공격을 탐지 및 방어할 수 있도록 설계 단계에서부터 고려하여 적용
 - FW(Firewall)/IPS(Intrusion Prevention System): 운영센터 네트워크에 대한 비인가 접근으로부터 보호, 특정 트래픽의 이용량이 급격히 증가하거나, 정상적이지 않은 트래픽을 탐지하여 차단
 - SIEM(Security Information and Event Management): 데이터의 흐름을 수집하고 모니터링
- 인증 및 접근제어: 사용자 단말(시스템, 기기 등) 인증 및 중요 정보(미터 정보, 요금 정보, 제어 정보, 개인정보 등)에 대한 접근 제어 기능 구현
 - 가입자 식별 및 인증: 정당한 가입자에 대한 식별(가입자 식별자) 및 인증을 수행하여 불법적인 가입자의 EMS에 대한 접근을 제어 적용
 - 중요정보 접근제어: 정당한 가입자만 정보(미터 정보, 요금 정보, 제어 정보 등)에 접근할 수 있도록 인증 및 접근 제어 적용
 - 세션 접근 제어: 보안 프로토콜 사용을 통한 세션의 접근 제어
 - 추가 인증: 로그인 이후 중요 서비스 이용 시 가입자 추가 인증 수행

- FEMS 시스템 보안: 웹서비스 취약점, 바이러스 감염 등 운영센터 내부의 시스템에 대한 침해 공격 방지 기능 구현
 - 웹방화벽(WAF): 운영센터 시스템에 대한 웹서비스 취약점 공격 방어
 - 보안 패치 및 백신 업데이트: 악성 코드 감염으로 인한 불법 제어 명령 전송 및 DoS 공격 방지를 위해 보안 패치 및 백신 업데이트
 - 제어 및 모니터링: 고객 에너지 관리 시스템으로 유입되는 패킷 정보(가입자 식별자, 기기 식별자, IP)에 대한 제어 및 모니터링
 - 보조기억매체 통제: 인가되지 않은 보조 기억 매체(예: USB, 외장 하드 등)의 기기의 연결을 차단
 - 로그 생성 및 관리: EMS에 저장된 정보(미터 정보, 요금 정보, 제어 정보)의 유출을 막기 위해 로그생성 및 관리 수행
- 안전한 암호 알고리즘 사용: 안전성이 검증된 암호알고리즘을 사용하여 FEMS에서 저장되거나 전송되는 민감한 데이터의 기밀성, 무결성을 보장해야 하며, 보안강도 112 비트 이상을 사용. 암호 알고리즘은 일반적으로 대칭키 암호, 해시 함수, 공개키 암호가 적용됨
 - 저장된 중요 정보 유출 방지를 위해 검증된 S/W 보안 모듈 또는 HSM을 사용하여 암호화와 관련된 일련의 과정(암호화, 복호화, 전자서명)을 보호
 - 대칭키의 경우 112비트 이상의 암호강도를 갖는 암호 알고리즘을, 공개키의 경우 2048비트 이상의 암호강도를 갖는 암호 알고리즘을 사용

7. FEMS 네트워크 및 시스템 보안 대책

7.1 FEMS 관련 산업제어시스템(ICS) 보안 표준(NIST 800-82 ICS 보안 가이드)

- 산업제어시스템(ICS: Industrial Control Systems) 보안 표준 NIST(National Institute of Standards and Technology) 800-82에서는 업무망과 공장망 간 직접 접속을 통제하기 위해 Plant DMZ(DeMilitarized Zone)를 구성하고, 단방향 게이트웨이를 통해 중요 네트워크 영역에 대한 보안 접속을 통제하도록 권고함. 또한, OT(Operational Technology)영역에서 가장 중요한 요소인 가용성을 보장하기 위해 장비 이중화에 대한 부분을 강조함
- 네트워크 분할 및 격리 보안
 - 암호화 또는 네트워크 장치 강제 분할에 의해 시행되는 논리적인 네트워크 분리

- 물리적인 네트워크 분리를 통해 영역 간 트래픽의 모든 상호 접속을 완전히 차단
- 보안 요구사항 및 영역을 적용하기 위해 다양한 네트워크 계층에서 다양한 기술을 활용할 수 있는 네트워크 트래픽 필터링
 - ◆ 네트워크 IP 및 경로 정보에 기초하여 다른 시스템과 통신할 수 있는 시스템을 제한하는 네트워크 계층 필터링
 - ◆ 의도한 목적과 현재의 작동 상태에 기초하여 네트워크의 다른 시스템과 통신할 수 있는 시스템을 제한하는 상태 기반 필터링
 - ◆ 각 시스템이 네트워크의 다른 시스템들과 통신할 수 있는 서비스의 수와 유형을 제한하는 포트 및 프로토콜 수준 필터링
 - ◆ 일반적으로 응용 프로그램 계층에서 시스템들 간의 통신 내용을 필터링하는 응용 프로그램 필터링

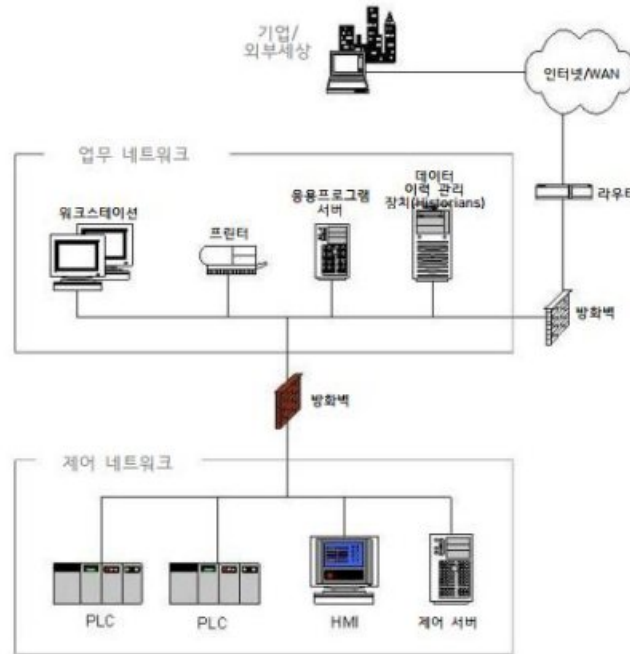
● 경계 보호

- 상호 연결된 보안 영역 간의 정보의 흐름을 제어하여 악의적인 사이버 적과 비 악성 오류 및 사고로부터 산업제어시스템을 보호
- 경계 보호 장치: 게이트웨이, 라우터, 방화벽, 네트워크 기반 악성 코드 분석 및 가상화 시스템, 침입탐지 시스템, 암호화된 터널, 관리 인터페이스, 단방향 게이트웨이
 - ◆ 기본적으로 통신 트래픽을 거부하고 예외적으로 통신 트래픽을 허용(즉, 모두 거부, 예외적으로 허용)
 - ◆ 외부 영역의 정보시스템 자원(예: 파일, 연결 또는 서비스) 요청에 대해 매개자의 역할을 하는 프록시 서버
 - ◆ 심층 패킷 검사 방화벽 및 XML 게이트웨이를 통한 정보의 무단탈취 방지
 - ◆ 하나 이상의 조직, 시스템, 응용 프로그램 및 개인 별로 인가 및 인증된 근원지 및 목적지 주소 쌍 간의 통신만 허용
 - ◆ 산업제어 시스템 구성요소의 네트워크 주소를 발견되지 않도록 은폐
 - ◆ 서로 다른 보안 영역 간에 단방향 데이터 흐름 구현
 - ◆ 네트워크 수동 모니터링 설정으로 이례적인 통신을 능동적으로 감지 경고

● 방화벽

- 산업제어시스템 환경에서 방화벽은 대부분의 경우 산업제어시스템 네트워크와 업무 네트워크 사이에 배치됨.

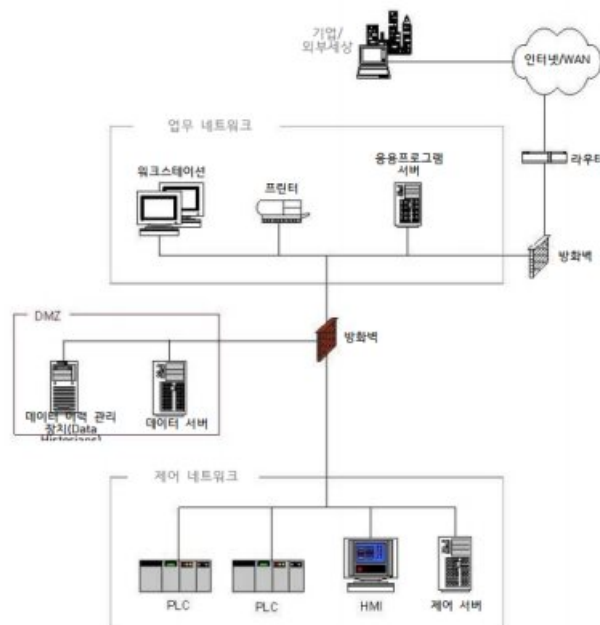
- 제어시스템 호스트 컴퓨터 및 컨트롤러 사이에서 원하지 않는 상호 접근을 제한함으로써 보안성을 향상시킴
 - 네트워크에서 비필수 트래픽을 제거함으로써 잠재적으로 제어네트워크의 반응성을 향상시킴
 - 불필요한 모든 통신 차단(예: 송신 및 목적지 IP 주소쌍, 서비스, 포트, 연결 상태 및 방화벽에서 지원되는 지정된 응용 프래그먼트 및 프로토콜 기반으로 차단)
 - 산업제어시스템 네트워크에 접근하려는 사용자에게 대한 보안 인증 수행
 - 사용자는 업무 기능에 필요한 제어 네트워크의 노드에만 도달할 수 있도록 제한 및 허용함으로써 의도적이거나 우연히 인가되지 않은 장치에 대한 접근 및 제어 권한을 얻을 가능성을 줄임
 - 트래픽 모니터링, 분석 및 침입 탐지에 대한 정보 흐름 기록
 - 심각한 사이버 사고시 업무 네트워크에서 산업제어시스템 네트워크를 단절하는 결정이 내려지는 경우 단절시킬 수 있도록 최소 연결 설계
- 경계네트워크구간(DMZ)과 방화벽
 - 업무네트워크와 제어네트워크 사이의 방화벽
 - ◆ 업무 네트워크와 제어 네트워크 사이의 단순 2포트 방화벽을 도입함으로써 보안성 향상. 제어 네트워크에 대한 외부 공격 가능성을 줄임
 - ◆ 문제점: 데이터이력관리장치가 제어 네트워크상에 있을 경우 방화벽은 업무 네트워크에 있는 호스트들이 데이터이력관리장치와 통신할 수 있도록 허용해야 함. 업무 네트워크상에 악성 또는 잘못 구성된 호스트에서 비롯된 패킷들이 데이터이력관리장치를 통해 제어 네트워크로 전달될 수 있음.



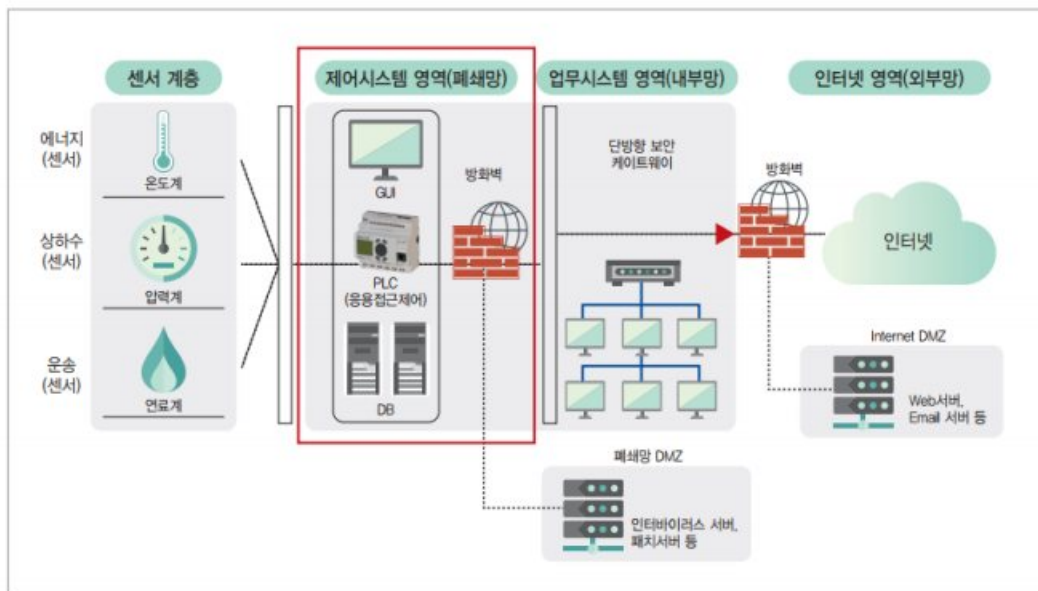
<업무 네트워크와 제어 네트워크 사이 방화벽 (그림출처: NIST ICS 보안 가이드)>

■ 업무네트워크와 제어네트워크 사이의 DMZ 및 방화벽

- ◆ 업무 네트워크와 제어 네트워크 사이에 DMZ 설정을 통해 업무 네트워크에서 제어 네트워크로 향하는 직접 통신 경로 차단을 통한 보안성 강화.



<그림> 업무네트워크와 제어네트워크 사이 DMZ와 방화벽(그림출처: NIST ICS 보안가이드)



<산업제어시스템 구성도 (그림출처: KISA, 스마트공장 사이버보안 가이드)>

구분	보안 요구사항	ICS 보안 표준		정보보호 표준	스마트공장 보안가이드	
		NIST800-82	ISA/IEC 62443	NIST800-53	유출방지가이드	최소보안체크리스트
인증 및 권한 관리	인증 및 권한 관리	O	O	O	O	O
	기기인증	-	O	O	-	-
네트워크 보호/원격제어	네트워크 분리	O	O	O	O	-
	Plant DMZ 구성	O	O	-	O	-
	ICS망/업무망간 프록시 서버	O	O	-	-	-
	단방향 게이트웨이	O	-	-	-	-
	침입 차단	O	O	O	-	O
	원격 제어	O	O	O	O	O
	무선 보안	O	O	O	-	O
	DDOS 방지	-	-	O	-	-
	모니터링, 감사, 탐지	O	O	O	O	O
	보안 모니터링, 로그관리, 사고 탐지/대응/복구	O	O	O	O	O
침입/악성코드 탐지	침입탐지	O	O	O	-	-
	악성코드/바이러스 탐지	O	O	O	O	O
시스템/데이터/어플리케이션 보안	화이트리스트 적용	O	-	-	-	-
	매체제어	O	O	O	O	-
	장비 이중화(Redundancy)	O	-	-	-	-
	패치 적용	O	O	O	O	-
	데이터 암호화	O	O	O	O	O
	물리적 접근통제	O	O	O	O	-
물리보안	영상정보기기 보안	-	-	-	-	O

<NIST 800-82 스마트공장 보안 요구사항>

7.2 FEMS 네트워크 및 시스템 보안 대책

7.2.1 FEMS 운영센터 내부 네트워크 구성

- FEMS 운영센터 내부에 FEMS 서비스 운영과 관련한 네트워크를 무선 네트워크로 구성하거나, 무선 네트워크에 연결하는 것을 금지함
- FEMS 운영센터에서는 운영센터 시스템들을 기능, 보안 중요도에 따라 서버영역, DMZ 영역, 관리영역 등의 물리적 서브넷으로 구성하여 운영센터 운영에 필요한 시스템들 간에만 통신이 가능하도록 구성함.

- 운영센터에서는 비인가 시스템, 악성코드 감염 시스템, 보안 패치 및 업데이트 등의 보안 정책을 따르지 않는 시스템에 대하여 네트워크 연결과 사용을 제한하는 네트워크 접근제어를 수행하도록 구성함.
 - 운영센터에서는 스위치 및 라우터에서 MAC 주소, ACL (Access Control List) 설정과 구성을 통해 인가된 시스템에 대해서만 운영센터 네트워크 연결과 사용을 허용함.
 - 운영센터에서는 NAC (Network Access Control) 설치 및 구성을 통해 인가된 시스템에 대해서만 운영센터 네트워크 연결과 사용을 허용함.
 - FEMS 운영센터를 클라우드 환경에서 구축 시 KISA 및 SK 인포섹의 클라우드 보안 가이드를 반드시 참조하여 FEMS 클라우드 서비스 환경을 구축해야 함.
 - ◆ KISA, 클라우드 서비스 정보보호 안내서, 2011.
 - ◆ KISA, 클라우드 정보보호 안내서, 2017.
 - ◆ KISA, 클라우드 취약점 점검 가이드, 2020.
 - ◆ SK 인포섹, 클라우드 보안 가이드 2019.

7.2.2 FEMS 운영센터 연계구간 네트워크 구성

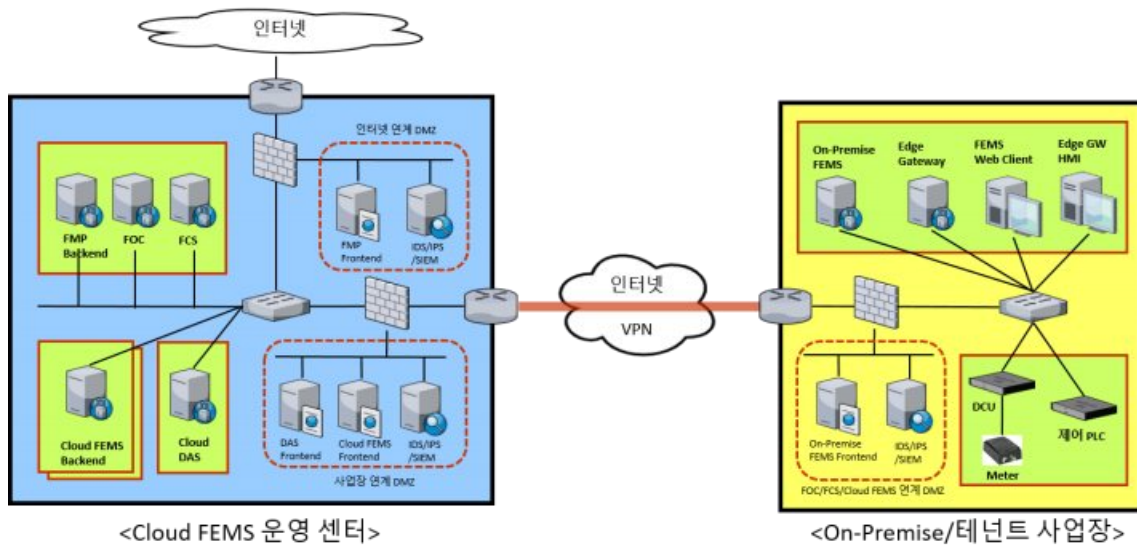
- FEMS 운영에 필요한 정보시스템, FEMS 기기 등이 인터넷과 직접적으로 연계되지 않는 것을 원칙으로 함. 단, FEMS 비즈니스 모델 실현을 위해 반드시 인터넷을 이용한 연계가 필요한 경우, 운영센터에서는 안전한 네트워크 구성, 암호화 통신 등의 보안대책을 수립 후 인터넷과 연계함.
- 운영센터 운영자 PC를 인터넷에 연계하여 사용할 경우, 운영센터에서는 운영자 PC와 연결된 네트워크와 FEMS 서비스 네트워크를 분리함.
- 운영센터에서는 인터넷과 서비스 네트워크 외부 연계 라우터를 분리하여 운영할 수 있음.
- 인터넷과 서비스 네트워크 외부 연계 라우터를 하나로 사용할 경우, 운영센터에서는 라우터의 라우팅 및 접근통제 정책, 침입차단시스템의 차단정책을 엄격하게 관리하여 운영자 PC에서 악성코드가 감염되더라도 서비스 네트워크의 정보시스템에 전파되지 않도록 두 네트워크 간 통신을 단절함.
- 운영센터에서는 인터넷과 연계된 운영자 PC에 FEMS 관련 자료를 보관하지 않도록 관리함.
- FEMS 운영센터는 운영센터 외부 연계 구간에 침입차단시스템을 설치하여 DMZ를 구성함.
 - 인터넷 웹 서비스 제공 시, 운영센터는 인터넷 연계 DMZ를 구성하여 운영센터 내부

와 외부 시스템 간 통신하도록 구성함.

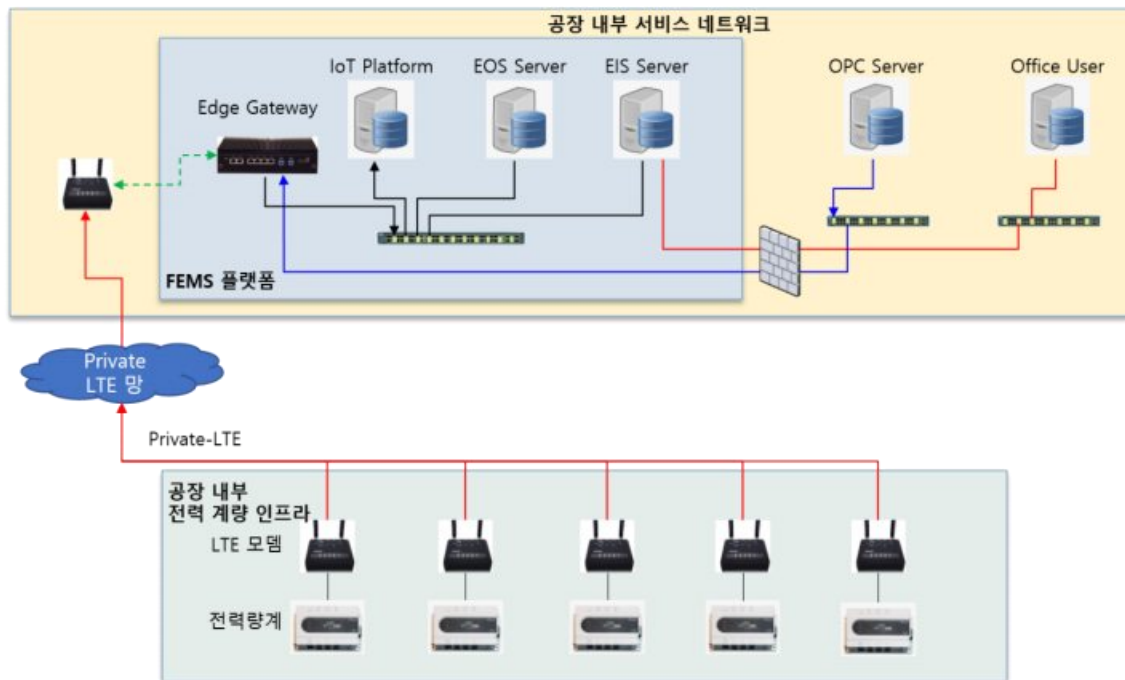
- 운영센터는 FEMS 실증 사이트 연계 DMZ를 구성하여 운영센터 내부와 외부 시스템 간 통신하도록 구성함.
- 운영센터는 운영센터 연계 구간에 침입탐지시스템, 침입방지시스템, DDoS 대응시스템을 설치하여 유해트래픽의 탐지 또는 차단 기능을 수행함.
 - 인터넷 웹 서비스 제공시, 운영센터는 인터넷 연계 구간에 침입탐지시스템, 침입방지시스템, DDoS 대응시스템을 설치하여 운영함.
 - 운영센터는 FEMS 실증 사이트 연계 구간에 침입탐지시스템 및 침입방지시스템을 설치하여 운영함.
- FEMS 운영센터와 FEMS 실증사이트 연계구간 네트워크 구성
 - FEMS 운영센터와 FEMS 실증사이트 연계 구간은 전용선을 사용하고, 전용선을 사용하지 않더라도 안전성이 보장되지 않을 경우 VPN(Virtual Private Network)을 적용함.

7.2.3 FEMS 실증사이트 내부 네트워크 구성

- OA 영역과 FA 영역을 세분화하여 네트워크 분리하고, 세분화된 네트워크는 방화벽과 네트워크 장비 ACL(Access Control List) 설정으로 접근을 통제함.
- 업무네트워크와 공장네트워크 간 데이터 전송을 중재하는 Plant DMZ를 구축하여 네트워크 간 직접적인 연결을 제한하고, 단방향 게이트웨이 구축을 통해 공장 설비 및 유틸리티 제어네트워크에 대한 외부로부터 접근을 원천적으로 차단하는 것을 권고함.
- 실증사이트 내부 네트워크는 유선네트워크 구성을 원칙함. 다만, 유선네트워크 구축이 불가능하여 반드시 무선망을 구축해야 할 경우에는 외부 인터넷과 연계되지 않는 전용보안 게이트웨이를 통해 사업장 내에 허가된 FEMS 기기만 통신가능하도록 하여 무선통신채널의 보안성을 보장하는 Private 보안 무선망을 구축해야 함.



<FEMS 보안 네트워크 구성 예>



7.2.4 클라우드 플랫폼(Docker, Kubernetes)기반 FEMS 시스템 보안 대책

- Cloud FEMS는 ISO/IEC 27017 인증을 받은 클라우드 플랫폼 기반으로 서비스 제공할 것을 권장하며 다음의 보안 솔루션 도입을 적극 고려해야 함
 - WAF(Web Application Firewall): 웹 애플리케이션 보안에 특화되어 개발된 솔루션으로 SQL Injection, Cross-Site Scripting(XSS)등과 같은 웹 공격 탐지 및 차단

- DLP(Data Loss Prevention): 개인정보, 공장에너지 관리 및 제어 정보, 지적재산(IP) 등을 포함하는 기밀정보 유출 방지 솔루션
- SIEM(Security Information and Event Management): 빅데이터의 방대한 정보 속에서 단순한 로그 수집 및 분석이 아닌 사후에 추적 등이 가능하도록 상관분석과 포렌식 기능을 제공해주는 지능형 위협에 대한 조기 경고 모니터링 체계
- Docker 보안 대책
 - Docker 인증 권한 제어 기능 적용
 - TLS 인증서를 활용 Docker daemon 접근 클라이언트 또는 사용자 검증 설정
 - TCP Socket을 통해 네트워크 연결 후 원격 접속하도록 구축할 경우 SSL/TCL 프로토콜 적용 전송 데이터 보호
 - 컨테이너 런타임 또는 이미지에 불필요하게 과도한 권한이 설정된 경우 잠재적인 권한 상승 공격에 악용될 가능성이 존재하므로 불필요한 권한 삭제
 - SK 인포섹, 클라우드 보안 가이드(컨테이너 보안) 준용
- Kubernetes 보안 대책
 - API 서버 인증 제어: 사용자 계정관리, 설정을 통한 비인증 서비스 접근에 대한 차단, 안전한 방식의 인증 시스템 사용을 통한 API 서버에 대한 엄격한 제어 수행
 - 사용자 또는 그룹에 직무에 필요한 특정 호스트, 컨테이너 및 이미지에서 특정 작업을 수행할 수 있는 최소한의 권한만 부여함
 - ABAC(Attribute-Based Access Control), RBAC(Role based Access Control), Node 및 Webhook 등의 인증 모듈 중 최소 하나의 인증 모듈을 지원하고, API서버 내 설정을 통해 권한모듈을 구성함
 - API 서버와 Kubelet, 사용 간의 통신시 SSL(Secure Sockets Layer)/TLS(Transport Layer Security) 프로토콜을 이용하여 네트워크상에 Secrets 및 Keys와 같은 주요 데이터 보호 및 API 서버와 통신하는 클라이언트 검증을 수행함
 - Etcd와 클라이언트 또는 etcd 클러스터의 다른 peer와 통신시 SSL/TLS 프로토콜을 이용하여 네트워크 상에서 주요 데이터 보호 및 etcd에 접근 요청하는 클라이언트, etcd peer에 대한 검증을 수행함
 - PodSecurityPolicy를 통해 Pod 내 컨테이너의 권한에 대한 정책 및 볼륨 및 파일 권한 등 Pod 내 컨테이너가 불필요하게 과도한 권한을 가지지 않도록 해야 하며 네트워크 및 포트에 대한 정책 설정을 통해 접근 제어를 구현해야 함

- Kubelet 인증 제어, 권한제어, SSL/TLS 적용
- SK 인포섹, 클라우드 보안 가이드(컨테이너 보안) 준용

7.2.5 글로벌 클라우드 서비스 플랫폼 적용시 보안 대책

- 아마존 AWS(Amazon Web Services) 보안 기술
 - Amazon Config: AWS 리소스의 변경사항을 추적하고 감사하는 서비스
 - Amazon GuardDuty: 관리형 위협 탐지 및 통지 서비스
 - AWS Inspector: 에이전트 기반의 보안 취약점 점검 서비스
 - Amazon Macie: 기업의 민감한 중요 데이터에 대한 식별과 유출 차단을 위한 서비스
 - Amazon Security Hub: AWS 계정 전반에 걸쳐 우선순위가 높은 보안 경고 및 규정 준수 상태를 종합적으로 확인할 수 있는 서비스
 - AWS CloudTrail, CloudWatch, Detective: 대응 단계에서 침해에 대한 조사를 위한 서비스
- 마이크로소프트 Azure 보안 기술
 - Azure Monitor: 애플리케이션, 인프라, 네트워크 등의 모니터링
 - Azure Sentinel: Cloud Native SIEM을 제공하는 SaaS 형태의 서비스
 - Azure Active Directory: Single Sign-On 및 다단계 인증 기능 제공
 - Azure Security Center: 보안 정책 및 자동화를 사용하여 대규모 환경에서 신속하게 위협을 식별 및 대응
- 구글 GCP(Google Cloud Platform) 보안 기술
 - Cloud Identity and Access Management: 조직 전체에 적용되는 보안 정책에 관한 통합 뷰를 제공하고 규정 준수를 위한 감사 기능을 제공
 - Cloud Key Management Service: Google Cloud에서 암호화 키를 관리하는 서비스
 - Cloud Asset Inventory: 서비스 중인 모든 자원을 가시화하여 모니터링 및 분석하는 기능
 - Security Command Center: Google Cloud 표준 보안 및 위협 데이터베이스이며 Google Cloud 보안 및 데이터 위협을 탐지하고 대응하기 위한 지능적인 대시보드 및 분석 시스템

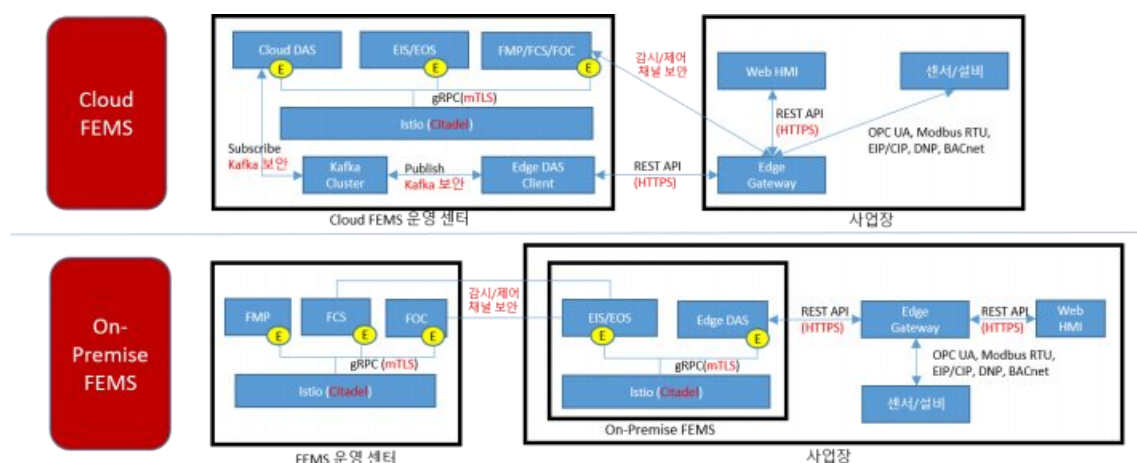
8. FEMS 데이터 및 통신 보안 대책

8.1 Cloud FEMS의 데이터 및 통신 보안 대책

- Cloud FEMS 내부 서비스 간 통신: Service Mesh (Istio, Envoy Proxy): Citadel 기반 보안, gRPC mTLS 보안
- Cloud DAS <-> Kafka <-> Edge DAS Client 통신: Kafka 보안솔루션 적용 (SSL, SASL[OAuth2, Kerberos])
- Edge DAS <-> EdgeGW REST API (또는 gRPC) 통신: HTTPS, TLS 적용, OAuth, Bi-directional Certification
- EdgeGW <-> 센서/설비: 센서/설비 연동 프로토콜 표준 보안 규격 준수

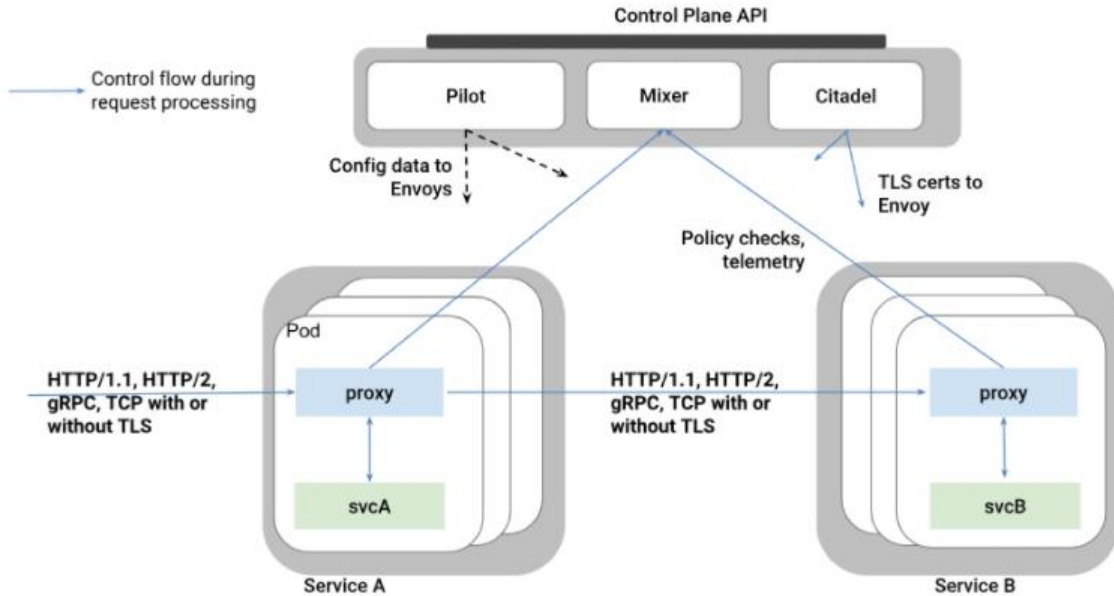
8.2 On-premise FEMS의 데이터 및 통신 보안 구조

- On-premise FEMS 내부 서비스 간 통신: Service Mesh (Istio, Envoy Proxy): Citadel 기반 보안, gRPC TLS 보안
- Edge DAS <-> EdgeGW REST API (또는 gRPC) 통신: HTTPS, TLS 적용, OAuth, Bi-directional Certification
- EdgeGW <-> 센서/설비: 센서/설비 연동 프로토콜 표준 보안 규격 준수



8.3 Cloud FEMS 운영센터 내부 데이터 및 서비스 통신 보안 대책

- Cloud FEMS는 MSA(Micro Service Architecture) 기반으로 Cloud DAS, EIS/EOS, FMP, FCS, FOC 등의 마이크로서비스(컨테이너화된 애플리케이션)들이 상호 통신하며, 통신 채널 보안을 위한 메시지 암호화, 인증 및 접근제어를 위한 대책이 필요함.
- 본 과제에서는 컨테이너화된 애플리케이션의 배포, 확장 및 관리를 자동화하기 위한 오픈소스 컨테이너 오케스트레이션 엔진인 쿠버네티스를 사용하며, 오픈소스 서비스 메쉬 플랫폼인 Istio를 이용하여 쿠버네티스 환경에서 실행되는 마이크로서비스의 연결, 모니터링 및 보안 기능을 제공함.
- 쿠버네티스 환경에서 마이크로서비스간 통신 보안 대책 (Istio 플랫폼 적용)
 - Istio 환경에서는 기본적으로 마이크로서비스 간 통신 트래픽을 TLS를 이용해서 암호화함.
 - 서비스 인증과 인가: 서비스에 대한 인증 기능을 제공하며, 서비스와 서비스간 호출에 서의 서비스 인증과 서비스를 호출하는 클라이언트 인증 기능을 제공함.
 - 서비스 간 인증: 서비스 간 인증은 인증서를 이용하여 양방향 mTLS(mutual TLS) 인증을 통해 서비스가 상호 식별 및 인증함.
 - 서비스와 사용자 간 인증: 서비스 간 인증뿐 아니라 엔드유저 즉 사용자 클라이언트를 인증할 수 있으며, JWT 토큰을 이용해서 서비스에 접근할 수 있는 클라이언트를 인증할 수 있음.
 - 인가를 통한 권한 통제: 서비스 접근권한 통제를 위한 RBAC을 지원함. 인증된 사용자나 서비스는 각각 사용자 계정이나 쿠버네티스의 서비스 어카운트로 계정으로 정의되고, 이 계정에 역할을 부여해서 역할 기반으로 서비스 접근 권한을 정의할 수 있음.



<Istio 기반 MSA 서비스 통신 보안 구성 (그림출처: <https://techcafe.tistory.com/133>)>

- Cloud FEMS 운영센터 내 데이터 수집 및 처리를 위한 Cloud DAS를 위한 Kafka 클러스터 환경에서의 보안 대책

◆ Kafka 환경에서의 인증

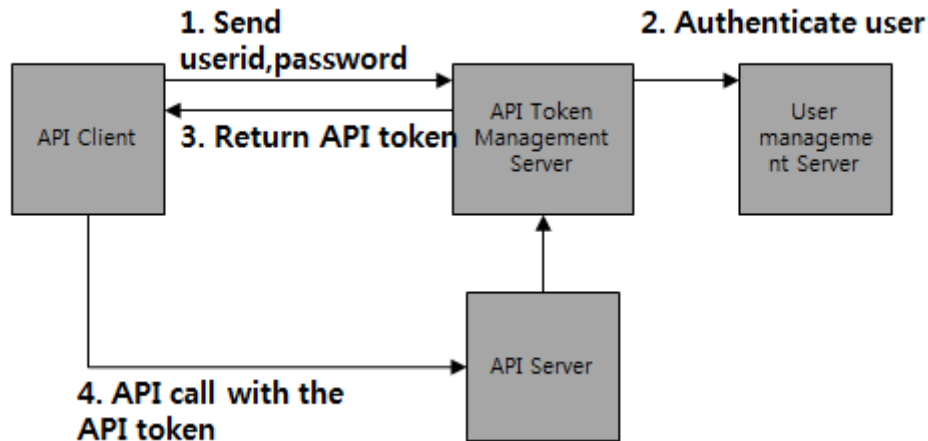
- SSL(Secure Sockets Layer) 방식: 인증서를 이용한 인증 방식
 - SSL 방식을 적용할 경우 클라이언트에서 메시지가 암호화되어 전달되며 이 암호화된 메시지는 브로커에서 복호화가 됨.
- SASL(Simple Authentication and Security Layer) 방식: SASL 프로토콜을 이용한 인증 방식
 - 인증 처리 방식을 요구사항에 맞게 변경할 수 있는 Plug-in 형태
 - 기본적으로 제공하는 SASL 4가지 메커니즘
 - ◆ PLAIN: 문자열 아이디/패스워드를 이용한 인증
 - ◆ SCRAM: Salt 등을 이용한 SCRAM 방식을 이용한 인증
 - ◆ OAUTHBEARER: OAuth2 방식을 이용한 인증
 - ◆ GSSAPI: Kerberos를 이용한 인증, 가장 강력한 보안성 제공

◆ Kafka 환경에서의 접근권한 제어

- 클라이언트 계정 정보를 바탕으로 권한을 확인, RBAC 지원

- 권한 관리가 가능한 카프카 리소스
 - Topic, Consumer Group, Cluster, Transaction ID, Delegation Token
- 권한 관리가 가능한 작업
 - Read, Write, Create, Delete, Alter, Describe, ClusterAction 등
- Cloud FEMS 운영센터 (Edge DAS Client)와 사업장 (Edge GW)간 REST(REpresentational State Transfer) API 통신 보안 대책
 - ◆ REST API 인증 방식
 - API 키 방식 인증: 특정 사용자만 알 수 있는 일종의 문자열인 API 키를 사용하여 API를 호출한 사용자를 인증하는 방식. 모든 클라이언트들이 같은 API 키를 공유하기 때문에 API 키 노출되면 전체 API가 뚫려 버리는 문제가 발생하기 때문에 높은 수준의 보안 인증을 요구하는 경우에는 권장하지 않음
 - API 토큰 방식 인증: 사용자 ID, Password 등으로 사용자를 인증한 후, 그 사용자가 API 호출에 사용할 기간 동안 유효한 API 토큰을 발급해서 API 토큰으로 사용자를 인증하는 방식. 사용자 인증 단계에서 보안 수준에 따라 아래와 같이 여러가지 방식을 사용할 수 있음.
 - HTTP(HyperText Transfer Protocol) Basic Auth: 사용자 ID와 Password를 HTTP header에 Base64 인코딩 형태로 넣어서 인증을 요청하는 방식. 중간에 패킷을 가로채서 이 헤더를 Base64로 디코딩하면 사용자 ID와 Password가 그대로 노출되기 때문에 반드시 HTTPS(HTTP over Secure Socket Layer) 프로토콜을 사용해야 함.
 - Digest Access Authentication: HTTP Basic Auth의 단점을 보완하기 위한 방법으로 클라이언트가 서버로부터 nonce라는 일종의 난수값을 받은 후에 사용자 ID와 Password를 이 난수값을 이용해 Hash화하여 서버로 전송하는 방식. Hash 알고리즘으로 사용하는 MD5가 보안레벨이 낮고 Dictionary Attack에 취약하기 때문에 추가적인 보안(HTTPS) 로직을 함께 사용할 것을 권고함.
 - IP White List를 이용한 터널링: API 서버 앞단에 HAProxy나 Apache와 같은 웹서버를 배치하여 특정 URL로 들어오는 IP List를 제한하거나, 전체 API가 특정 서버와의 통신에 사용된다면 하드웨어 방화벽 자체에 들어올 수 있는 IP List를 제한할 수 있음.
 - Bi-directional Certification (Mutual SSL): 가장 높은 수준의 인증 방식을 제공할 수 있는 개념으로, 클라이언트와 서버 모두 인증서를 놓고 양방향으로 SSL

을 제공하면서, API 호출에 대한 인증을 클라이언트의 인증서를 이용하는 방식. 공인 기관에서 발행된 인증서를 사용한다면 API를 호출하는 쪽의 신원을 확실하게 할 수 있고, 메시지 암호화도 되기 때문에 가장 높은 수준의 인증을 제공합니다.



<API 토큰 기반 REST API 통신 보안 구조 (그림출처: <https://bcho.tistory.com/955>)>

◆ REST API 인가 방식

- RBAC (Role Based Access Control): 권한 부여의 대상이 되는 사용자나 그룹을 Object, 각 개별 권한을 Permission, 사용자의 역할을 Role이라고 정의함. Role에 Permission을 매핑한 다음 Object에 Role을 부여하는 방식임.
- ACL (Access Control List): 사용자(또는 그룹과 같은 권한의 부여 대상)에게 직접 권한을 부여하는 방식임.

◆ REST API 인가 처리 위치

- 클라이언트에 의한 API 권한 인가 처리: API를 호출하는 클라이언트 쪽에서 사용자의 권한에 따라서 API를 호출하는 방식임. 클라이언트가 신뢰할 수 있는 경우에만 사용할 수 있음.
- Gateway에 의한 권한 인가 처리: API 호출이 들어오면 API Access Token을 사용자 정보와 권한 정보로 API token management 정보를 이용해서 변환 한 후에 접근하고자 하는 API에 대해서 권한 인가를 처리함.
- 서버에 의한 API 권한 인가 처리: 가장 일반적이고 보편적인 방법으로 API 서버의 비즈니스 로직단에서 API 요청을 처리하는 방식임.

◆ 네트워크 레벨 암호화

- HTTPS 보안 프로토콜을 사용하여 메시지 자체를 암호화하여 전송함. Man in

the middle attack을 막기 위해 공인 인증서를 사용해야 함.

■ 사업장 내 Edge GW와 계측기 및 센서 통신 보안 대책

- ◆ NIST 산업제어시스템 보안 가이드(NIST-800-82 Guide to Industrial Control Systems (ICS) Security)를 준용해야 함.
- ◆ Edge GW와 PLC 간 OPC UA 통신
 - OPC UA는 보안에 대한 표준 정의를 제공함. OPC UA(Open Platform Communications Unified Architecture)의 보안은 application의 변경 없이도 간편하게 보안 표준이 적용될 수 있도록 설계되어 있으며, 사용자 인증 및 권한 부여, OPC UA 시스템 간 메시지 서명 및 메시지 암호화를 지원함.
- ◆ Edge GW와 스마트미터 또는 PLC 간 Modbus 통신 보안
 - Modbus는 OSI 7계층에 위치하는 요청-응답기반 프로토콜이며, 패킷 프레임 내에 Function Code를 통해 서비스를 구별하고 제공함. Modbus-TCP는 별도로 보안 기능을 제공하지 않기 때문에 사업장의 물리적 보안 확보가 어려울 경우 E-Modbus, E-ModbusSec, Modbus-TLS, Modbus-S 등의 보안성이 향상된 Modbus 프로토콜을 적용해야 함.
 - Modbus 통신 지원 PLC (Programmable Logic Controller)또는 스마트미터와 Edge GW가 연동하는 경우에는 네트워크 보안 위협에 노출될 수 있기 때문에 OA(Office Automation) 및 FA(Factory Automation) 망 간에 방화벽 등의 보안 솔루션 도입을 통하여 FA망과 EdgeGW 보안을 강화해야 함.

9. 참고문헌

- 정보통신산업진흥원, ICT기반 ESCO 사업 가이드라인, 2014
- (주)에너지토피아, FEMS 표준개발 및 보급지원제도 적용방안 연구, 2014.
- 한국인터넷진흥원, 스마트공장 사이버보안 가이드, 2019.
- 한국인터넷진흥원, 스마트에너지 사이버보안 가이드, 2019.
- 에너지관리공단, 공장에너지관리시스템(FEMS) 설치확인 기준 가이드, 2015.
- 에너지관리공단, 에너지관리시스템(FEMS) 지원관리 운영규정, 2014.
- SK 인포섹 블로그, 스마트 팩토리화 보안 1편, 스마트 공장에서 주의해야 할 보안 위협,

2019.

- SK 인포섹 블로그, 4차 산업혁명의 필수요건, 스마트팩토리 보안 3편 - 스마트팩토리 보안대책, 2019.
- OSIA S&TR Journal, 스마트공장 사이버 위협과 보안 기술, 2018.
- NIST, NIST-800-82 Guide to Industrial Control Systems (ICS) Security, 2015.
- ISO, ISO/IEC 27017:2015 Information technology – Security techniques – Code of practice for information security controls based on ISO/IEC 27002 for cloud services, 2015
- KISA, 클라우드 서비스 정보보호 안내서, 2011.
- KISA, 클라우드 정보보호 안내서, 2017.
- KISA, 클라우드 취약점 점검 가이드, 2020.
- SK 인포섹, 클라우드 보안 가이드(컨테이너 보안), 2019.
- Kubernetes, <https://kubernetes.io/ko/docs/concepts/security/overview/>
- <https://velog.io/@beryl/Istio-%EA%B0%9C%EB%85%90#1-envoy>
- <https://techcafe.tistory.com/133>
- <https://bcho.tistory.com/955>
- IITP, 클라우드 보안 기술 및 표준 동향, 2020.